

Simulazione Spear-Phishing & Adversarial AI: Tecniche di Attacco e Strategie di Difesa

Nicola Madonna

11 Luglio 2026

1. Sintesi

Il presente report descrive lo sviluppo e l'analisi di una simulazione di attacco informatico mirato, basato sulle metodologie di Ingegneria Sociale e sull'impiego avanzato dell'Intelligenza Artificiale (Adversarial AI). Il progetto prende in esame l'intero ciclo di una minaccia di tipo Spear-Phishing: dalla raccolta iniziale di informazioni su fonti aperte (OSINT) relative a un bersaglio di alto profilo, fino alla generazione di esche digitali sofisticate tramite modelli linguistici (LLM). Il documento delinea le vulnerabilità umane sfruttate e propone un framework analitico per il riconoscimento delle minacce e l'innalzamento delle difese aziendali.

2. Introduzione

Nel moderno panorama della sicurezza informatica, il fattore umano si conferma essere uno degli anelli più sollecitati e vulnerabili della catena difensiva. Gli attacchi di Spear-Phishing non mirano a colpire indiscriminatamente una vasta platea di utenti, ma si focalizzano su singoli individui chiave (VIP, dirigenti, CEO) attraverso pretesti estremamente personalizzati e contestualizzati. L'avvento dell'Intelligenza Artificiale Generativa ha ulteriormente abbassato le barriere tecniche per gli aggressori, rendendo indispensabile lo studio e la simulazione di queste tecniche in ambienti accademici e difensivi per comprendere come anticipare le minacce reali.

3. Obiettivi

L'obiettivo cardine dell'attività è analizzare in modo sistematico i meccanismi psicologici e tecnologici della società potenziata dall'intelligenza artificiale, definendo al contempo le relative contromisure analitiche e difensive. Nello specifico, il progetto si propone di raggiungere i seguenti traguardi operativi:

- **Efficacia nella Raccolta OSINT:** Dimostrare la capacità di condurre indagini rapide e mirate su fonti aperte per estrarre informazioni d'intelligence critiche (spostamenti logistici, reti relazionali, progetti in corso) relative a un target selezionato.
- **Modellazione del Pretesto Psicologico:** Progettare uno scenario di attacco personalizzato e coerente con i dati raccolti, applicando strategicamente i principi di persuasione di Cialdini (quali Autorità, Urgenza o Scarsità) per massimizzare la credibilità della sollecitazione.
- **Valutazione delle Tecniche di Adversarial AI:** Esplorare e documentare i limiti dei sistemi di moderazione degli LLM, elaborando strategie di prompting avanzate (es. jailbreaking o role-play) idonee a generare testi simulati a scopo formativo e di verifica.
- **Identificazione dei Segnali di Compromissione (Red Flags):** Sviluppare capacità critica nel dissezionare l'output malevolo generato, isolando le anomalie tecniche (es. discrepanze nei domini) e logiche necessarie ai team di sicurezza per intercettare la minaccia.

4. Raccolta di informazioni tramite OSINT

Il primo step consiste nello scegliere un bersaglio di alto profilo tra quelli indicati nella lista, il personaggio scelto è Lionel Messi.

É Effettuata una rapida ricerca su fonti aperte utilizzando strumenti suggeriti come *Google Dorking* o *Maltego*. L'obiettivo è raccogliere informazioni operative recenti sul target per identificare nello specifico:

- **Spostamenti recenti;**
- **Attività economiche e professionali;**
- **Reti relazionali.**

Google Dorking e Maltego

É stato utilizzato, inizialmente un Google Dorking ovvero sono stati cercate informazioni riguardanti il target su google con operatori di ricerca avanzata. Da questa questa ricerca sono state acquisite le seguenti informazioni:

- Messi si trova nell'hotel **Orgin Hotel Kansas City**
- non ha la possibilità di uscire e ne di vedere la famiglia, tranne in giorni specifici dopo le partite;
- a Kansas City si sono verificate diverse sommosse il 4 luglio, per protestare contro il governo Triumph.

Successivamente è stata eseguita una scansione tramite Maltego delle seguenti persone:

- Lionel Messi;
- Jorge Messi(padre);
- Antonela Rocuzzo(moglie);
- Pepe Costa(coordinato personale di Messi);

Dalle scansioni non sono emerse domini, email e password rilevanti, a scopo didattico mostro i diagrammi di uno dei target(Jorge Messi).

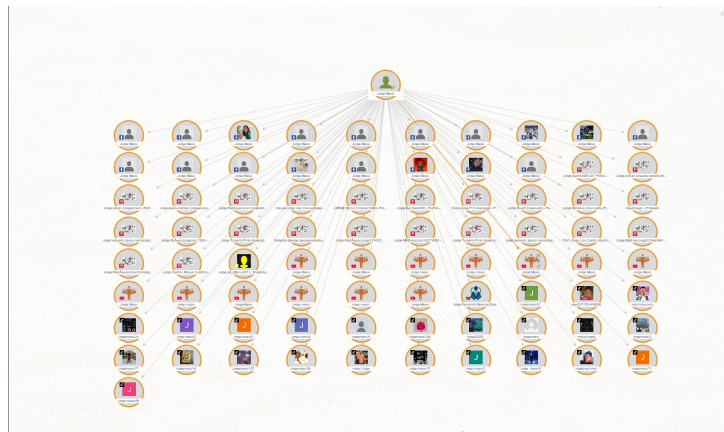


Figura 1: Screenshot interfaccia Maltego